СТОЛИЧНА ОБЩИНА- РАЙОН ”МЛАДОСТ”

Детска Градина № 202

гр.София 1784,ж.к.”Младост”1 , до блок 47,dg202sofia@abv.bg

ВЪТРЕШНИ ПРАВИЛА ЗА ЗАЩИТА НА ЛИЧНИТЕ ДАННИ*

ПРЕДМЕТ

Чл. 1. (1) Настоящите правила („Правилата“) определят реда, по който *[ДГ№ 202]*, с ЕИК 181437083 събира, записва, организира, структурира, съхранява, адаптира или променя, извлича, консултира, използва, разкрива чрез предаване, разпространяване или друг начин, по който данните стават достъпни, подрежда или комбинира, ограничава, изтрива, унищожава или обработва по друг начин лични данни за целите на своята дейност.
(2) В зависимост от конкретната ситуация, учебното заведение може да обработва данни в качеството на администратор или обработващ.
(3) Правилата са изготвени в съответствие с изискванията на Регламент (ЕС) 2016/679 на Европейския Парламент и на Съвета от 27 април 2016 г. относно защитата на физическите лица във връзка с обработването на лични данни и относно свободното движение на такива данни и за отмяна на Директива 95/46/ЕО (Общ регламент относно защитата на данните).

Чл. 2. Настоящите Правила уреждат:
(1) Принципите, процедурите и механизмите за обработка на личните данни;
(2) Процедурите за уведомяване на надзорния орган в случай на нарушения в сигурността;
(3) Процедурите за администриране на искания за достъп до данни, коригиране на обработваните данни, възражения и оттегляне на съгласия, както и администриране на искания за упражняване на други права, които субектите на лични данни имат по закон;
(4) Лицата, които обработват лични данни, и техните задължения;
(5) Правилата за предаване на лични данни на трети лица в България и чужбина;
(6) Необходимите технически и организационни мерки за защита на личните данни от неправомерно обработване и в случай на инциденти, като случайно или незаконно унищожаване, загуба, неправомерен достъп, изменение или разпространение;
(7) Техническите ресурси, прилагани при обработката на лични данни.

ДЕФИНИЦИИ

Чл. 3. За целите на настоящите Правила, използваните понятия имат следното значение:
• **ЗЗЛД** – Закон за защита на личните данни.

---

* Тази Вътрешни правила за защита на личните данни съдържат принципите, които организацията трябва да спазва, когато обработва лични данни за целите на своята дейност, включително лични данни на клиенти, доставчици и работници или служители. Правилата са в съответствие с изискванията на Общия регламент за защита на данните (Регламент 2016/679).

• **КЗЛД** – Комисия за защита на личните данни.
• **ОРЗД** – Регламент (ЕС) 2016/679 на Европейския парламент и на Съвета от 27 април 2016 г. относно защитата на физическите лица във връзка с обработването на лични данни и относно свободното движение на такива данни и за отмяна на Директива 95/46/ЕО (Общ регламент относно защитата на данните).
• **Длъжностно лице по защита на данните** – физическо лице или организация, определени съгласно изискванията на чл. 37 и сл. от ОРЗД.
[или – ако не е задължително определянето на длъжностно лице по защита на данните – алтернативно може да се включи:
• ***Лице, отговорно за личните данни*** *– лице, което е служител в учебното заведение или изпълнява функции по поръчение, на което са възложени задълженията във връзка със защитата и процесите по обработка на лични данни, уредени в тези Правила. Основните дейности на администратора или обработващия лични данни не се състоят в операции по обработване, които поради своето естество, обхват и/или цели изискват редовно и систематично мащабно наблюдение на субектите на данни или в мащабно обработване на специалните категории данни и на лични данни, свързани с присъди и нарушения.*
• **Администратор на лични данни** – физическо или юридическо лице, публичен орган, агенция или друга структура, която сама или съвместно с други определя целите и средствата за обработването на лични данни. В настоящите Правила „администратор“ обозначава учебното заведение.
• **Обработващ лични данни** – лице или организация, което въз основа на договор обработва лични данни, предоставени от учебното заведение, за уговорените цели.
• **Известия по защита на данните** – отделни известия, съдържащи информация, предоставяна на субектите на данни в момента, в който учебното заведение събира информация за тях. Тези известия могат да бъдат както общи (напр. адресирани към работници и служители или известия на уебсайта на организацията), така и отнасящи се до обработване със специфична цел.
• **Обработване на лични данни** – всяка дейност, която е свързана с използването на лични данни. Това включва: получаване, записване, съхранение, извършване на операция или серия от операции с данните като напр. организиране, редактиране, възстановяване, използване, предоставяне, изтриване или унищожаване. Обработването също включва и трансфер на лични данни до трети лица.
• **Псевдоминизиране** – заместването на информация, която директно или индиректно идентифицира физическо лице, с един или повече идентификатори („псевдоними”), така че лицето да не може да бъде идентифицирано без достъп до допълнителната информация, която следва да се съхранява отделно и да е поверителна.
• **Съгласие на физическо лице** – всяко свободно изразено, конкретно, информирано и недвусмислено указание за волята на субекта на данни, посредством изявление или ясно потвърждаващо действие, което изразява съгласие за обработка на лични данни, свързани с него.
•“**Специфични признаци“** са признаци,свързани с физическа, физиологична, генетична,психическа,психологическа,икономическа,културна,социална или друга идентичност на лицето.
•**“Регистър на лични данни“** е структурирана съвкупност от лични данни, достъпна по определени критерии,съобразно вътрешните документи на НСИ, която може да бъде централизирана и децентрализирана и е разпределена на функционален принцип.

•**“Съвместни администратори“** означава, че двама или повече администратори съвместно определят целите и средствата на обработването на лични данни.

Физическото лице, за което се отнасят данните (субект на данни), може да упражнява своите права в областта на защитата на личните данни по отношение всеки и срещу всеки от администраторите.

СУБЕКТИ НА ДАННИ И КАТЕГОРИИ ЛИЧНИ ДАННИ

Чл. 4. (1) Учебното заведение събира и обработва лични данни, необходими за осъществяване на своите права и задължения като работодател, доставчик на образователни услуги и контрагент при съблюдаване изискванията на приложимото законодателство. Личните данни, обработвани от учебното заведение, са групирани в регистри на дейностите по обработване, съдържащи правила за обработване на лични данни, отнасящи се до:
• работници и служители;
•изпълнители по граждански договори;
• кандидати за работа;
• доставчици на услуги.
(2) Относно **лицата, заети по трудови или граждански правоотношения в учебното завдение, и на кандидатите за работа**, се събират следните лични данни:
а) Идентификация: име; ЕГН (дата на раждане), постоянен и/или настоящ адрес, телефон, данни по лична карта или паспортни данни;
б) Образование и професионална квалификация; данни, свързани с образование, трудов опит, професионална и лична квалификация и умения;
в) Здравни данни: здравословно състояние, здравни книжки, ТЕЛК решения, медицински свидетелства, болнични листове и всяка прилежаща към тях документация;
г) Други данни: свидетелство за съдимост, когато се изисква представянето му съгласно нормативен акт или електронно свидетелство за съдимост, с което работодателят да се снабди, както и други данни, чието обработване е необходимо за изпълнение на правата и задълженията на учебното заведение като работодател.
(3) Относно физически лица, **контрагенти на учебното заведение**, се събират лични данни, които са необходими за изпълнението на законовите задължения на същото като доставчик на услуги, както следва:
• име; ЕГН (дата на раждане), постоянен и/или настоящ адрес, телефон, данни по лична карта или паспортни данни.
(4) Относно физически лица, **доставчици на услуги на учебното заведение**, се съхраняват лични данни, необходими за сключването и изпълнението на договори за предоставяне на услуги на учебното заведение от външни доставчици, както следва:
• име, ЕГН (дата на раждане), постоянен и/или настоящ адрес, телефон, данни по лична карта или паспортни данни; електронна поща.
(5) учебното заведение обработва чувствителни данни, само доколкото това е необходимо за изпълнение на специфичните му права и задължения в областта на трудовото и осигурително законодателство.

ЦЕЛИ И ПРИНЦИПИ НА ОБРАБОТВАНЕ НА ЛИЧНИТЕ ДАННИ

Чл. 5. Целите на обработването на лични данни са:
(1) управление на човешките ресурси, изплащане на трудовите възнаграждения и изпълнение на свързаните с това задължения на работодателя за удържане и плащане на здравни и социални осигуровки на служителите, на данъци, както и на други права и задължения на учебното заведение в качеството му на работодател;

(2) администриране на отношенията с контрагенти на учебното заведение и предоставяне на услуги;
(3) сключване и изпълнение на договори с доставчици за предоставяне на услуги на учебното заведение.
Чл. 6. Личните данни :
-да се обработват законосъобразно и добросъвестно;
-да се събират за конкретни, точно определени и законни цели и да не се обработват допълнително по начин, несъвместим с тези цели;

-допълнително обработване на личните данни за исторически, статистически или научни цели е допустимо, при условие че администраторът осигури подходяща защита, като гарантира, че данните не се обработват за други цели;

- да бъдат съотносими, свързани със и ненадхвърлящи целите, за които се обработват;--

-да бъдат точни и при необходимост да се актуализират;

-да се заличават или коригират, когато се установи, че са неточни или непропорционални по отношение на целите, за които се обработват;

- да се поддържат във вид, който позволява идентифициране на съответните физически лица за период не по-дълъг от необходимия за целите, за които тези данни се обработват;

-личните данни, които ще се съхраняват за по-дълъг период за исторически, статистически или научни цели, се поддържат във вид, непозволяващ идентифицирането на физическите лица.

Чл. 7. За да е законосъобразно обработването на данните, трябва да е налице поне едно от следните условия:

(1)Субектът на данните е дал своето съгласие;

(2)Това е необходимо за изпълнение на нормативно установено задължение.

(3) Обработването е необходимо за изпълнението на договор, по който субектът на данните е страна, или за предприемане на стъпки по искане на субекта на данните преди сключването на договор;
(4) Обработването е необходимо за спазването на законово задължение, което се прилага спрямо администратора;
(5) Обработването е необходимо, за да се защитят жизненоважни интереси на субекта на данните или на друго физическо лице;
(6) Обработването е необходимо за изпълнение на задача от обществен интерес;
(7) Обработването е необходимо за целите на легитимните интереси на администратора, освен когато пред тези интереси преимущество имат интересите или основните права и свободи на субекта на данни. Целите, за които се обработват лични данни на това основание, трябва да са описани в приложимите известия по защита на данните.

(8) Всички служители в учебното заведение при встъпване в длъжност се задължават да спазват конфиденциалност по отношение на базата данни в т. ч. лични данни, както и да не разгласяват данни и информация, станали им известни при и по повод изпълнение на служебните им задължения, като за тази цел подписват декларация по образец.

(9) Учебното заведение поддържа вътрешен ред като администратор на лични данни, като осигурява технически и организационни мерки за защита.

СЪГЛАСИЕ

Чл. 8. (1) Изразеното съгласие трябва да бъде свободно дадено, конкретно, информирано и недвумислено заявление.Ако съгласието за обработка на лични данни се дава чрез документ, който урежда и други въпроси, то следва да бъде изискано отделно от съгласието по други въпроси. Съгласието трябва да бъде дадено свободно.Такова съгласие е налично в случаите, когато субектът на данни има истински и свободен избор и е в състояние да откаже или да оттегли съгласието си, без това да доведе до вредни последици за него.

(2) Субектите на данни трябва да могат лесно да оттеглят съгласието си за обработване по всяко време, и оттеглянето трябва да бъде уважено своевременно. Ако не съществува друго условие за законосъобразност на обработването, с оттеглянето на съгласието то следва да се прекрати.
(3) Декларациите за съгласие се съхраняват от учебното заведение, докато се извършват действия по обработване на данни на това основание, с оглед спазването на принципа на отчетност.Съгласието остава едно от алтернативните условия за обработване на личните данни.
(4) Учебното заведение трябва да може да докаже неговото наличие.Субектът на данните следва да бъде информиран за последиците при отказ да даде съгласие за обработване на отделни категории лични данни.
(5)Съгласието може да бъде дадено онлайн. Това може да бъде осъществено чрез отбелязване на отметка в поле, избиране на технически настройки за услуги на информационното общество или друго заявление или поведение, което ясно показва, че субектът на данни е съгласен с предложеното обработване на неговите лични данни.Мълчанието, предварително отметнатите полета или липсата на действие на представляват съгласие.

ПРОЦЕДУРИ ПО ОБРАБОТВАНЕ НА ЛИЧНИТЕ ДАННИ

Процедура за обработване на личните данни, отнасящи се до лицата, заети по трудови или граждански правоотношения в учебното заведение, както и на кандидатите за работа
Чл. 9. (1) Администраторът възлага обработването на личните данни на определени негови служители, на които в длъжностната характеристика има вменени такива трудови функции.В зависимост от естеството на работа, обработването може да се възложи на повече от един обработващ данните.Обработващите личните данни, действат само по указания на администратора, освен ако в нормативен акт не е предвидено друго.
Личните данни, отнасящи се до лицата, заети по трудови или граждански правоотношения в учебното заведение, както и на кандидатите за работа, се събират

при и по повод набирането на персонал. Данните на всеки работник и служител на учебното заведение се съхраняват в лични досиета, като някои данни могат да се съхраняват или обработват и на технически носител. Данните от проведени конкурси и интервюта или събеседване се съхраняват на технически и/или хартиен носител, в зависимост от нуждата.
(2) Личните досиета се подреждат в специални картотечни шкафове със заключване, находящи се в кабинета на Лицето, отговорно за личните данни. Достъпът до кабинета се предоставя само на лицата, оправомощени да обработват личните данни, като за целта се създава специален ред за влизане в помещението чрез ключ, магнитна карта или друго подходящо средство и/или устройство и това се регламентира в нарочна заповед/индивидуален административен акт/, която се свежда до знанието на персонала на учебното заведение.
(3) Администраторът на лични данни предприема всички организационно-технически мерки за съхраняването и опазването на личните досиета и класьорите с информация, в това число ограничаване на достъпа до тях на външни лица и неоторизирани служители.
(4) Досиета на работниците и служителите, както и данните на кандидатите за работа, не се изнасят извън сградата на учебното заведение, освен в случаите когато това е предвидено в закон, като на всеки 7 дни обработващия лични данни ги архивира.

Процедура за обработване на лични данни, отнасящи се до клиенти и доставчици на услуги
Чл. 10. (1) Личните данни, отнасящи се до клиенти, се събират при подаване на заявка за предоставяне на услуга или сключване на договор от страна на учебното заведение с външния контрагент.
(2) Личните данни, отнасящи се до доставчици на услуги, се събират при сключване на договор с доставчик на услуги, като обичайно личните данни се съдържат в текста на самите договори, което е презумпция за безусловно изразено съгласие на страните.
(3) Личните данни се съхраняват на електронен и хартиен носител (подписани копия на сключените договори), които се класират в отделни досиета. Досиетата се съхраняват в шкафове, които се заключват, в кабинета на Лицето, отговорно за личните данни. Електронните данни се съхраняват в бази данни.

ДОКУМЕНТИРАНЕ НА ОБРАБОТКАТА НА ЛИЧНИ ДАННИ

Чл. 11. (1) Учебното заведение документира дейностите по обработване на лични данни при спазване на принципа на отчетност.
(2) Документацията трябва да е достатъчен вид и обем, за да докаже спазването на принципите за законосъобразно обработване на личните данни.
(3) Обработването на данни, свързано с предаване на данни на обработващи, установени в страната или чужбина; съхранение на данни на сървъри, собственост на трети лица; архивиране или изтриване на данни; въвеждане на псевдонимизация, както и всяка друга обработка, чиито параметри са различни от описаните в тези правила, се документира чрез създаване на протоколи, които съдържат следната информация:
(а) целите на обработването;
(б) категориите лични данни и категориите субекти на данни;
(в) категориите получатели, пред които са или ще бъдат разкрити личните данни, включително получателите в трети държави;
(г) предаването на лични данни на трета държава;

(д) когато е възможно, предвидените срокове за изтриване на различните категории данни;
(е) общо описание на техническите и организационни мерки за сигурност.
(4) Протоколите се изготвят от лицата, които извършват съответната обработка на данни по указания от Лицето, отговорно за личните данни.
(5) Съвкупността от всички протоколи, съдържащи гореописаната информация, съставлява регистъра на дейностите по обработването, съгласно чл. 30 от ОРЗД.

МЕРКИ ЗА ЗАЩИТА НА ЛИЧНИТЕ ДАННИ

Чл.12 Приемане на план за действие за въвеждане на определените технически и организационни мерки

-Определяне на отговорник и екип.

- Определяне на срокове и етапи за изпълнение.

- Осигуряване на необходими финансови, технически и човешки ресурси.

(1) Физическа защита в учебното заведение се осигурява чрез набор от приложими технически и организационни мерки за предотвратяване на нерегламентиран достъп и защита на сградите и помещенията, в които се обработват и съхраняват лични данни.
Основните приложими организационни мерки за физическа защита в учебното заведение включват определяне на помещенията, в които ще се обработват лични данни, както и на тези, в които ще се разполагат елементите на комуникационно-информационните системи за обработване на лични данни, вкл. и определяне на организацията на физическия достъп.

Като помещения, в които ще се обработват лични данни*,* се определят всички помещения, в които с оглед нормалното протичане на учебния и административния процес, се събират, обработват и съхраняват лични данни. Достъпът до тях е физически ограничен само за служители с оглед изпълнение на служебните им задължения. Когато в тези помещения имат достъп и външни лица, в помещенията се обособява непублична част, която е физически ограничена и достъпна само за служители, на които е необходимо да имат достъп с оглед изпълнението на служебните им задължения.
Комуникационно-информационните системи, използвани за обработка на лични данни, се разполагат в помещения, достъпът до които е ограничен само до тези служители, които за изпълнение на служебните си задължения се нуждаят от такъв достъп до данните, както и лицата, натоварени със служебни ангажименти за поддръжката на нормалното функциониране на тези системи. Последните нямат достъп до съхраняваните в електронен вид данни.
Организацията на физическия достъп до помещения, в които се обработват лични данни, е базирана на ограничен физически достъп (на база заключващи системи). Достъп се предоставя само на служителите, на които той е необходим, за изпълнение на служебните им задължения.
Като *зони с контролиран достъп* се определят всички помещения на територията на учебното заведение, в които се събират, обработват и съхраняват лични данни.
Достъпът до системите, обработващи по електронен способ лични данни, е ограничен чрез уникални потребителски идентификатори и пароли, а електронните носители, са защитени по адекватен начин, в зони с контрол на достъпа.

Чл. 13. (1) Всички помещения, в които се съхраняват и обработват лични данни, са с контрол на достъпа. Възможните технически средства за контрол на достъпа са:
- охрана на помещенията;
- устройства за разпознаване чрез магнитна карта и/или ключ;

- наблюдение с видеокамери в коридорите;
- политика на допускане на външни лица до помещенията на учебното заведение само с придружител от персонала на същото.
(2) Помещенията на учебното заведение са надеждно обезопасени посредством противопожарни мерки съгласно българското законодателство.

Мерки за документална защита
Чл. 14. (1) Учебното заведение установява процедури по обработване на лични данни, регламентиране на достъпа до данните, процедури по унищожаване и срокове за съхранение, подробно разписани в тези Правила. За отделни категории данни може да се предвиди псевдонимизиране по предложение на Лицето, отговорно за личните данни.
(2) Размножаването и разпространението на документи или файлове, съдържащи лични данни, се извършва само и единствено от упълномощени служители при възникнала необходимост.

Персонални мерки на защита
Чл. 15. (1) Преди заемане на съответната длъжност лицата, които осъществяват защита и обработване на личните данни:
- поемат задължение за неразпространение на личните данни, до които имат достъп;
- запознават се с нормативната база, вътрешните правила и политики на учебното заведение относно защитата на личните данни;
- преминават обучение за реакция при събития, застрашаващи сигурността на данните;
- инструктирани са за опасностите за личните данни, които се обработват от учебното заведение;
- задължават се да не споделят критична информация помежду си и с външни лица, освен по установения с тези Правила ред.
(2) При постъпване на работа всички служители преминават обучение за реакция при събития, застрашаващи сигурността на данните, и обучение относно задълженията на учебното заведение, свързани с обработката на лични данни, и мерките за защита на данните, които следва да предприемат в процеса на работа. Последващи обучения и тренировки на персонала се провеждат периодично, за да се гарантира познаване на нормативната уредба, потенциалните рискове за сигурността на данните и мерките за намаляването им.

Мерки за защита на автоматизирани информационни системи и криптографска защита
Чл. 16 (1) Достъп до операционната система, съдържаща файлове с лични данни, имат само лица, чиито служебни задължения или конкретно възложена задача налагат такъв достъп. Достъпът се осъществява чрез парола.
(2) Защитата на електронните данни от неправомерен достъп, повреждане, изгубване или унищожаване, се осигурява посредством:
- поддържане на антивирусни програми;
- въвеждане на пароли за компютрите, чрез които се предоставя достъп до личните данни, и файловете, които съдържат лични данни;
- периодични проверки на целостта на базата данни и актуализиране на системната информация, поддържане на системата за достъп до данните;
- периодично архивиране;
периодично архивиране на данните на отделни електронни носители, както и чрез съхраняване на информацията на хартиен носител.

Когато данните се намират на сървър, архивирането им се извършва от определено за целта лице, с вменена трудова функция, относима към ЗЗЛД. Когато данните се намират на изолирани компютри, архивирането им се извършва от оператора на съответния компютър.

(3) Архивиране на личните данни на технически носител се извършва периодично с оглед съхранение на информацията.

НАРУШЕНИЯ НА СИГУРНОСТТА

Чл. 17. (1) Нарушение на сигурността на данни възниква, когато данните, за които учебното заведение отговаря, са засегнати от инцидент със сигурността, в резултат на който се нарушава поверителността, наличието или целостта. Ако това се случи и има вероятност нарушението да представлява риск за правата и свободите на дадено лице, учебното заведение трябва да ***уведоми надзорния орган, без ненужно забавяне най-късно до 72 часа, след като е узнало за нарушението***. Ако нарушението на сигурността на данните представлява висок риск за засегнатите лица, всички те също трябва да бъдат информирани, освен ако не са въведени ефективни технически и организационни мерки за защита или други мерки, които гарантират, че вече няма вероятност рискът да се случи на практика.Лицата, идентифицирали признаци на нарушение на сигурността на данните, са длъжни да докладват незабавно на Лицето, отговорно за личните данни, като му предоставят цялата налична информация.

(2) Лицето, отговорно за личните данни, извършва незабавно проверка по подадения сигнал, като се опитва да установи дали е осъществено нарушение на сигурността и кои данни са засегнати.
(3) Лицето, отговорно за личните данни, докладва незабавно на Директора на учебното заведение наличната информация за нарушението на сигурността, включително информация относно характера на инцидента, времето на установяването му, вида на щетите, предприетите към момента мерки и мерките, които счита, че трябва да се предприемат.
(4) След съгласуване с ръководството на учебното заведение , Лицето, отговорно за личните данни, предприема мерки за предотвратяване или намаляване последиците от пробива и възможностите за възстановяване на данните.
(5) При спешност, когато съгласуване с ръководството би забавило реакцията и би нанесло големи щети, Лицето, отговорно за личните данни, може по своя преценка да предприеме мерки за предотвратяване или намаляване последиците от нарушението на сигурността. В този случай Лицето, отговорно за личните данни, уведомява незабавно ръководството за предприетите мерки и съобразява последващи действия с получените инструкции.

Чл. 18. (1) В случай че нарушението на сигурността създава вероятност от риск за правата и свободите на физическите лица, чиито данни са засегнати, и след одобрение от ръководството на учебното заведение, Лицето, отговорно за личните данни, организира уведомяването на КЗЛД.
(2) Уведомлението до КЗЛД съдържа следната информация:
(а) описание на нарушението на сигурността; категориите и приблизителният брой на засегнатите субекти на данни и категориите и приблизителното количество на засегнатите записи на лични данни;

(б) името и координатите за връзка на Лицето, отговорно за личните данни;
(в) описание на евентуалните последици от нарушението на сигурността;
(г) описание на предприетите или предложените мерки за справяне с нарушението на сигурността, включително мерки за намаляване на евентуалните неблагоприятни последици.
(3) Когато има вероятност нарушението на сигурността на личните данни да породи висок риск за правата и свободите на физическите лица, Лицето, отговорно за личните данни, без ненужно забавяне и при спазване на приложимото законодателство уведомява засегнатите физически лица.

Чл. 19. (1) Учебното заведение води регистър на нарушенията на сигурността, който съдържа следната информация:
(а) дата на установяване на нарушението;
(б) описание на нарушението – източник, вид и мащаб на засегнатите данни, причина за нарушението;
(в) описание на извършените уведомявания: уведомяване на КЗЛД и засегнатите лица, ако е било извършено;
(г) предприети мерки за предотвратяване и ограничаване на негативни последици за субектите на данни и за учебното заведение;
(д) предприети мерки за ограничаване на възможността от последващи нарушения на сигурността.
(2) Регистърът се води в електронен формат от Лицето, отговорно за личните данни.

ПРЕДОСТАВЯНЕ НА ЛИЧНИ ДАННИ НА ТРЕТИ ЛИЦА

Чл. 20. (1) Учебното заведение може при необходимост да предоставя лични данни на трети лица, действащи в качеството на обработващ, когато това е предвидено в нормативен акт или въз основа на изричен договор.
(2) В случаите на предоставяне на данните на служители, клиенти или доставчици на услуги на обработващ, учебното заведение:
(а) изисква достатъчно гаранции от обработващия за спазване на законовите изисквания и добрите практики за обработка и защита на личните данни;
(б) сключва писмено споразумение, лицето подписва декларация или се изготвя друг правен акт с идентично действие, който урежда задълженията на обработващия и отговаря на изискванията на чл. 28 от Регламент (ЕС) 2016/679;
(в) информира физическите лица, чиито данни ще бъдат предоставени на обработващ.
(3) Обработване на лични данни от обработващи извън ЕС/ЕИП е допустимо само когато:
(а) Европейската Комисия е приела решение, потвърждаващо, че страната, към която се извършва трансферът, осигурява адекватно ниво на защита на правата и свободите на субектите на данни;
(б) Налице са подходящи мерки за защита – като например Обвързващи Корпоративни Правила (ОКП), стандартни договорни клаузи, одобрени от Европейската Комисия, одобрен кодекс за поведение или сертификационен механизъм;
(в) Субектът на данни е дал своето изрично съгласие за трансфера, след като е информиран за възможните рискове, или
(г) Трансферът е необходим за една от целите, изброени в ОРЗД, включително изпълнението на договор със субекта, защита на обществения интерес, установяване и защита на правни спорове, защита на жизненоважните интереси на субекта на данни в случаите, когато той е физически или юридически неспособен да даде съгласие.

ОЦЕНКА НА ВЪЗДЕЙСТВИЕТО ВЪРХУ ЗАЩИТАТА НА ДАННИТЕ

Чл. 21. (1) Оценка на въздействието се извършва, когато това се изисква съгласно приложимото законодателство и с оглед на риска за физическите лица и естеството на обработка на лични данни, извършвана от учебното заведение. Оценка на въздействието се извършва за високорискови дейности по обработване. ОВЗД се изисква, когато има вероятност обработването да доведе до висок риск за правата и свободите на физическите лица. ОВЗД се изисква най-малко в следните три случая:

- системна и обширна оценка на личните аспекти на физическо лице, включително профилиране;
- обработване на чувствителни данни в голям мащаб;
- систематично мащабно наблюдение на обществените зони.

(2) Оценка на въздействието е необходимо при всяко въвеждане на ключова система или смяна на бизнес програма, която е свързана с обработване на лични данни, включително:
- първоначалното въвеждане на нови технологии или прехода към нови технологии;
- автоматизирано обработване, включително профилиране или автоматизиране вземане на решения;
- обработване на чувствителни лични данни в голям мащаб;
- мащабно, систематично наблюдение на публично обществена зона.

(3) За оценката се съставя протокол, който се предоставя при поискване от страна на КЗЛД.

УНИЩОЖАВАНЕ НА ДАННИТЕ

Чл. 22. (1) Унищожаване на личните данни се извършва от учебното заведение или изрично упълномощено лице, без да бъдат накърнявани правата на лицата, за които се отнасят данните, обект на унищожаването и при спазване на разпоредбите на относимите нормативни актове.
(2) Информацията в регистрите се унищожава след постигане на целите на обработката и при отпаднала необходимост за съхранение.
(3) Унищожаването на данни на хартиен носител се извършва чрез нарязване с шредер машина. Електронните данни се изтриват от електронната база данни по начин, непозволяващ възстановяване на информацията.

ЛИЦА, ОТГОВАРЯЩИ ЗА СЪБИРАНЕТО, ОБРАБОТКАТА И СЪХРАНЕНИЕТО НА ЛИЧНИТЕ ДАННИ И ДОСТЪП ДО ЛИЧНИ ДАННИ

Чл. 23. Лицето, отговорно за личните данни, и лицата, обработващи личните данни от името на учебното заведение, са физически или юридически лица, притежаващи необходимата компетентност и назначени и/или упълномощени със съответен писмен акт, включително и чрез настоящите Правила.

Чл. 24. Лицето, отговорно за личните данни:
- подпомага учебното заведение и лицата, обработващите личните данни при изпълняване на задълженията им по защита на личните данни, като осигурява

прилагането и поддържа необходимите технически и организационни мерки и средства за осъществяване на защитата на данните;
- осигурява нормалното функциониране на гореспоменатите системи за защита;
- осъществява контрол през целия процес на събиране и обработване на данните;
- изпълнява всички задължения по докладване и управление на нарушения на сигурността на данните;
- периодично изисква информация от лицата, обработващи лични данни, във връзка със събирането, достъпа и обработването им;
- уведомява учебното заведение своевременно за всички нередности, установени във връзка с изпълнение на задълженията му;
- унищожава данните от хартиените и техническите носители съгласно закона и сроковете, установени в тези Правила;
- преупълномощава физически или юридически лица с писмен акт, които да осъществяват защитата на личните данни.

Чл. 25. (1) Събирането, обработката, съхранението и защитата на личните данни се извършва само от лица, на които това е изрично указано и чиито служебни задължения или конкретно възложена задача налагат това.тези задължения следва да са предвидени в длъжностната характеристика на лицето.
(2) При възлагане на дейности, налагащи обработката на лични данни от регистрите на учебното заведение, доставчиците на услуги следва да спазват приложимите нормативни изисквания относно обработката на личните данни и процедурите на чл. 19 от тези Правила.
(3) Достъп до личните данни могат да имат и съответните държавни органи – съд, следствие, прокуратура, ревизиращи органи и др. Гореспоменатите могат да изискат данните по надлежен ред във връзка с изпълнението на техните правомощия.

ПРАВА НА СУБЕКТИТЕ НА ДАННИ

Чл. 26. (1) Всяко лице има право да иска достъп до своите лични данни, включително и да иска потвърждение дали данните, отнасящи се до него, се обработват, да се информира за целите на това обработване, категориите данни и за получателите на данните, както и за целите на всяко обработване на лични данни, отнасящи се до него.
(2) Правото на достъп се осъществява чрез искане на засегнатото физическо лице, получено на адреса по седалището на учебното заведение или официалната електронна поща.
(3) Всяко физическо лице има право да поиска заличаването, коригирането или блокирането на негови лични данни, обработването на които не отговаря на изискванията на закона.
(4) Всяко лице има право писмено да възрази срещу обработването на и/или предоставянето на трети лица на неговите лични данни без необходимото законово основание.
(5) учебното заведение е длъжно в двуседмичен срок от получаване на искане по предходните алинеи да уведоми заявителя дали са налице законовите основания за уважаване на искането. Ако учебното заведение установи, че са налице законовите основания да уважи искането, уведомява лицето и за реда, по който може да упражни правото си.
(6) Субектите на данни имат също правото да:
- оттеглят съгласието си за обработване по всяко време;

- възразят срещу употреба на личните им данни за цели, които не са регламентирани от закона и не са във връзка с дейността на учебното заведение;
- изискат информация за основанието, въз основа на което личните им данни са предоставени за обработване на обработващ извън ЕС/ЕИП;
- възразят срещу решение, взето изцяло на база на автоматизирано обработване, включително профилиране;
- бъдат уведомени за нарушение на защита на данните, което е вероятно да доведе до висок риск за техните права и свободи;
- подават жалби до регулаторния орган;
- в някои случаи да получат или да поискат техните лични данни да бъдат трансферирани до трета страна в структуриран, общо използван формат, подходящ за машинно четене (право на преносимост).

ПРОМЕНИ НА ВЪТРЕШНИТЕ ПРАВИЛА

Чл. 27. Учебното заведение може да променя тези Правила по всяко време. Всички промени следва да бъдат незабавно сведени до знанието на лицата, които засягат.

Настоящите Правила са приети и влизат в сила на деня на подписването им.

Петя Янкова
Директор на ДГ№ 202 Дата 20.10.2025г.

Гр.София